

Authentication & Security

Student OS Documentation — File 10

Authentication

Use secure password hashing if passwords are managed directly. Prefer secure, httpOnly cookies or another documented secure session strategy. Implement logout and session expiration.

Authorization

Every protected API verifies authentication and resource ownership. Future multi-role access uses RBAC with deny-by-default behavior.

Input Security

Validate all external input. Sanitize/escape output where appropriate. Use parameterized queries/ORM. Restrict upload size/type.

Secrets

Use environment variables or secret management. Never commit API keys, database passwords or signing secrets.

Web Security

Use HTTPS in production; secure cookies; CSRF protection when applicable; rate limiting; safe CORS configuration; security headers.

Privacy

Collect only necessary student data. Provide account/data deletion mechanisms appropriate to the product. Do not expose one student's academic records to another.

AI Security

Do not send sensitive data to an AI provider without appropriate authorization. Protect prompts and API keys server-side. Treat AI output as untrusted content.

Logging

Log useful operational events without logging passwords, tokens or unnecessary personal information.

Security Testing

Test unauthorized access, IDOR/resource ownership, invalid tokens, brute-force/rate-limit behavior, injection attempts, file upload validation and secret leakage.